

Confidential Model Checking as a Service

Bajnok Vencel

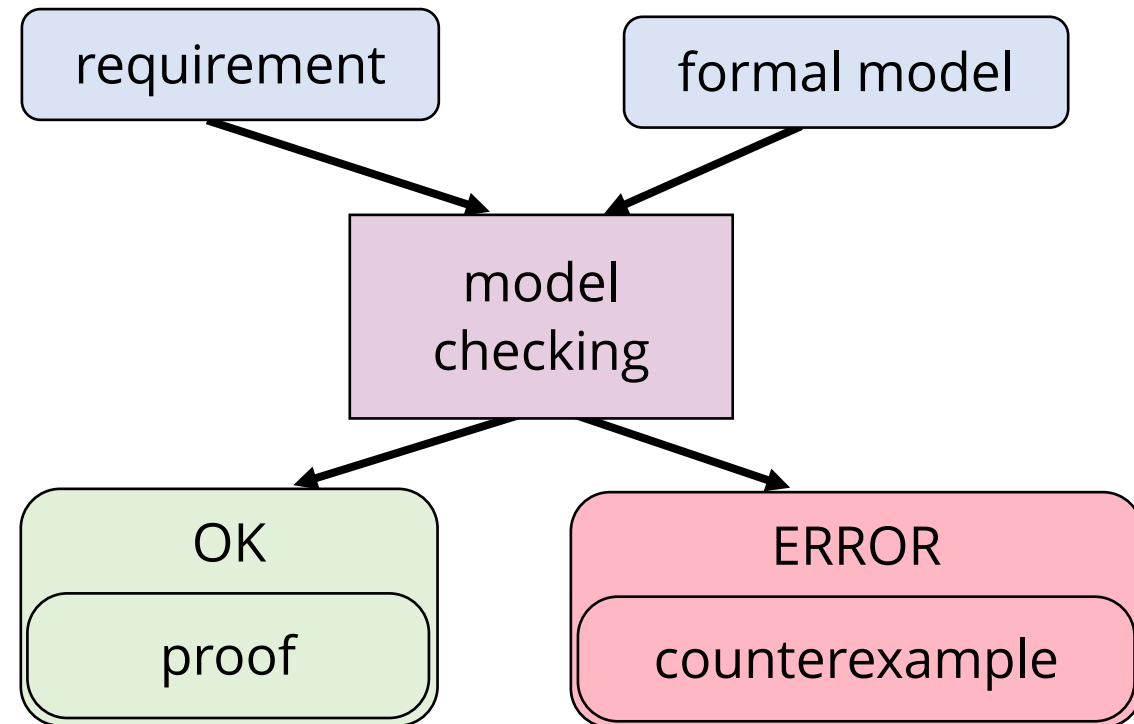
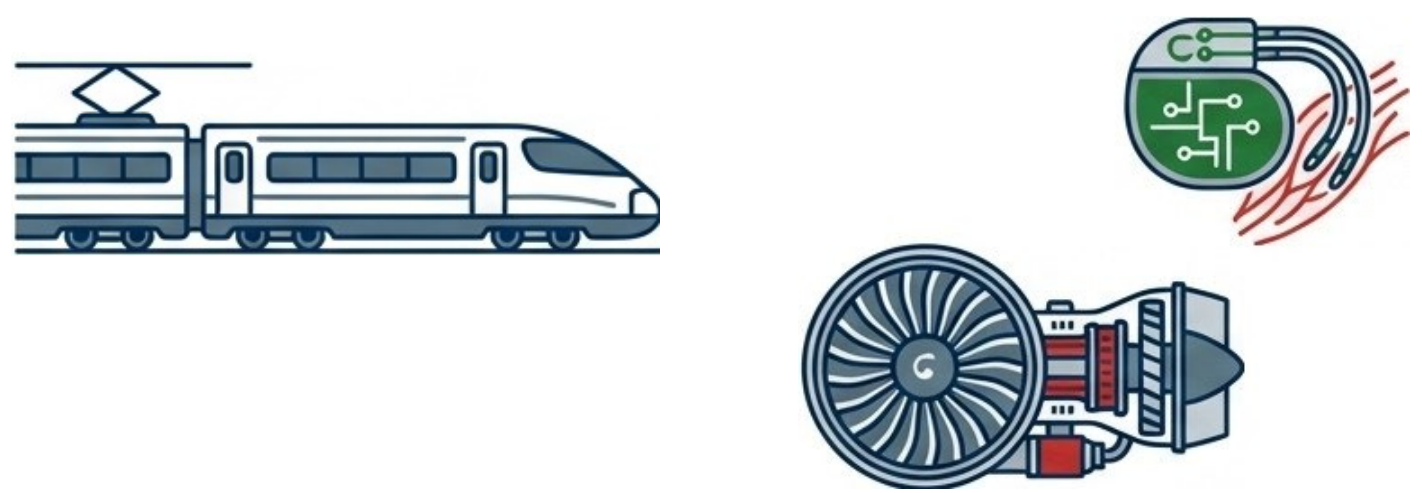
advisor: Dobos-Kovács Mihály



**Critical Systems
Research Group**

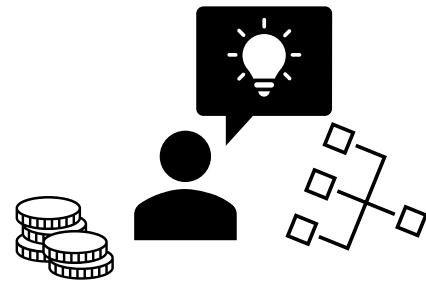
Background

- safety critical systems
- formal verification
- bottleneck
 - computational cost
 - expertise



Motivation

- SMEs
- researchers
- requirements
 - cost efficiency
 - data privacy and confidentiality
 - need of expertise
 - industry readiness
- current limitations
 - NDAs
 - local scalability



SaaS

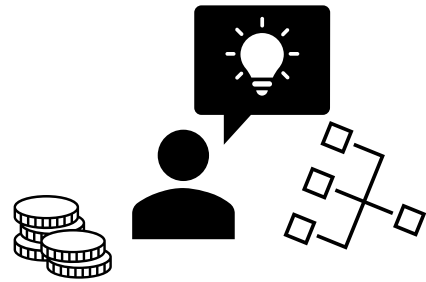


On-Premise



Motivation

- SMEs
- researchers



- requirements
 - cost efficiency
 - data privacy
 - need of exp
 - industry readiness

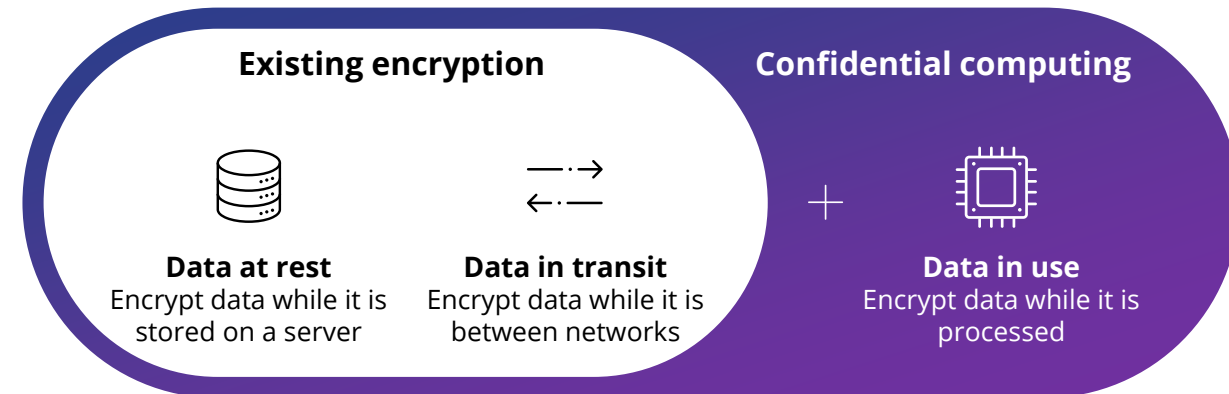
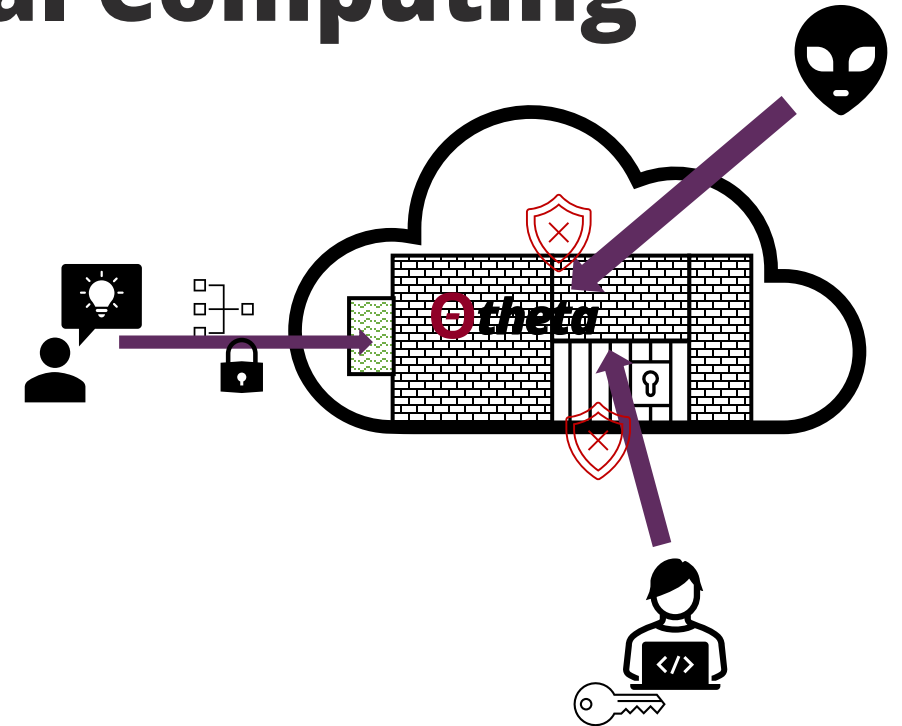
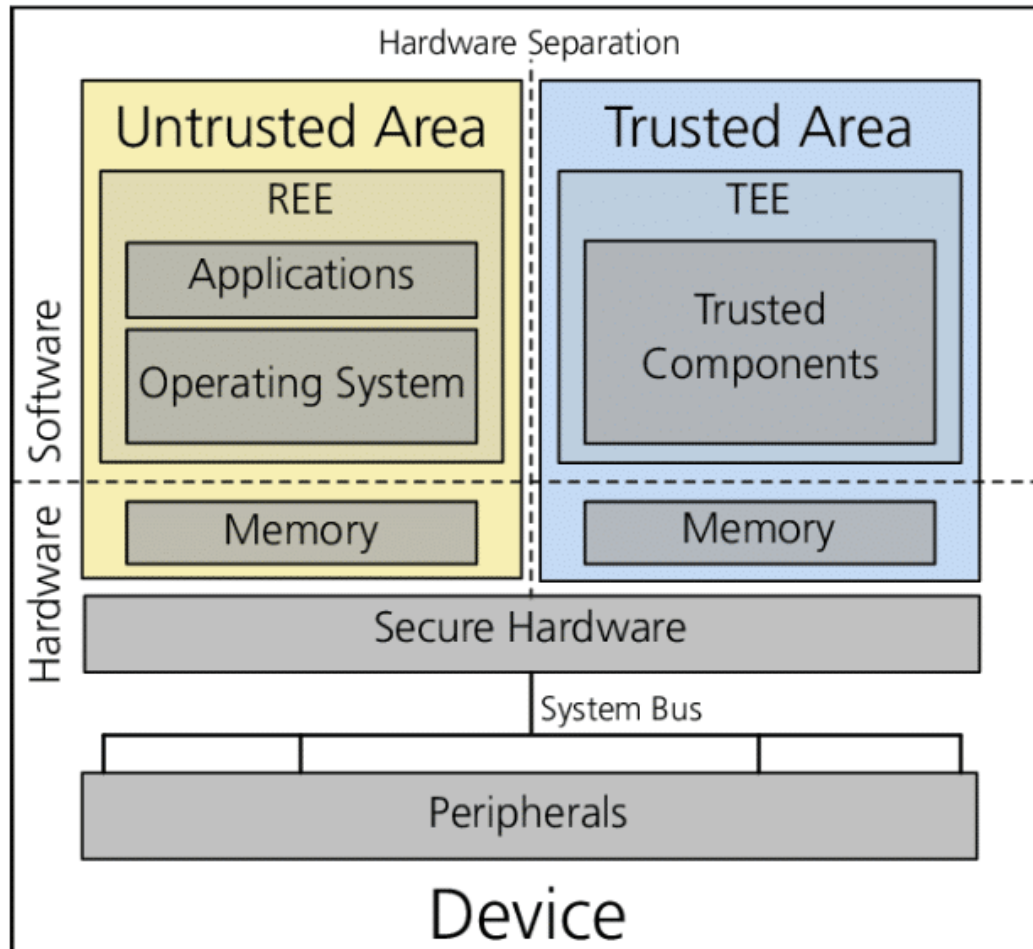
Goal: service where the infrastructure maintainer cannot access the user's model

- current limitations
 - NDAs
 - local scalability

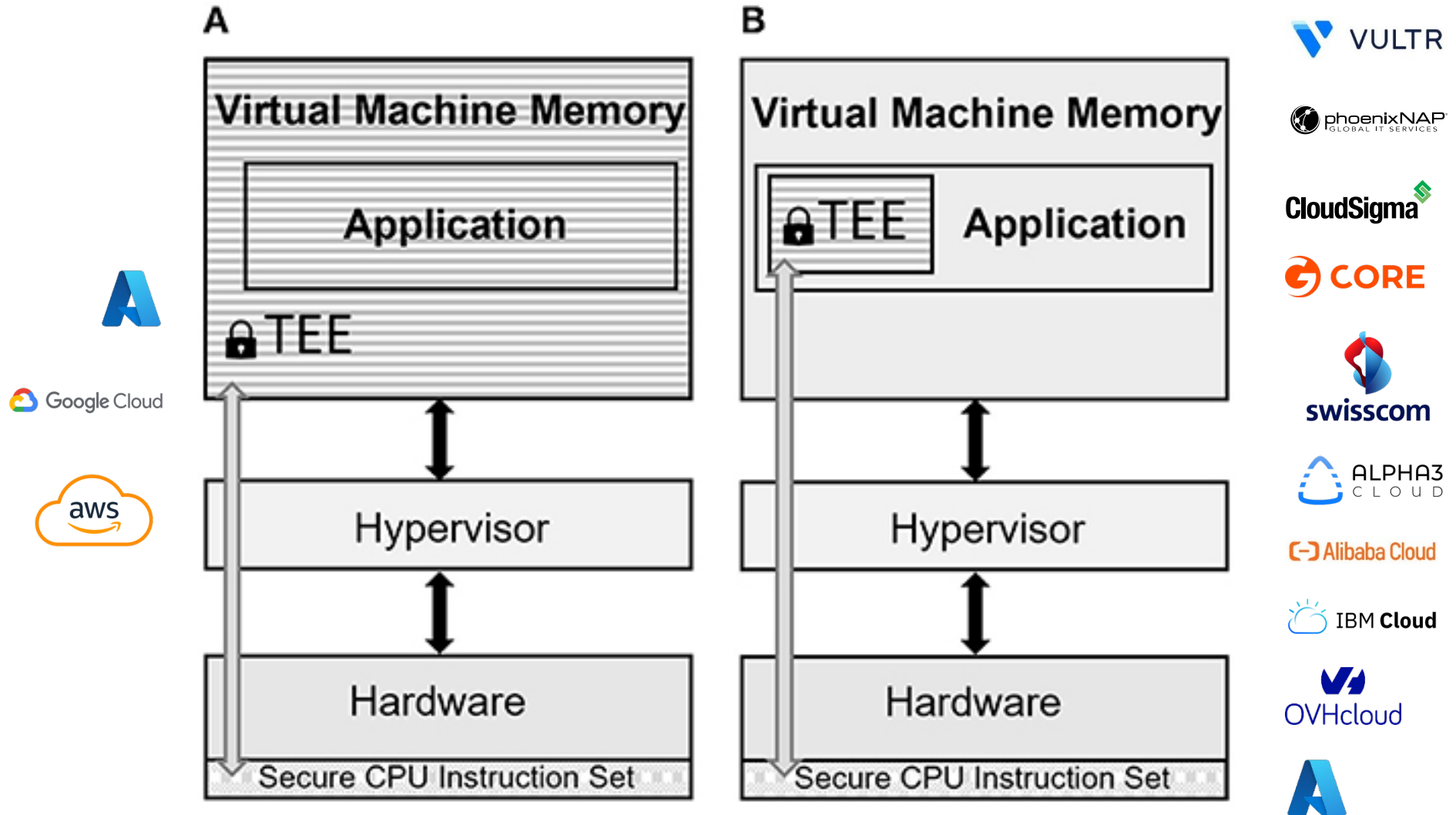
- Scalability
- Security
- Ease of use

Solution Concept: Confidential Computing

- TEE (Trusted Execution Environment)



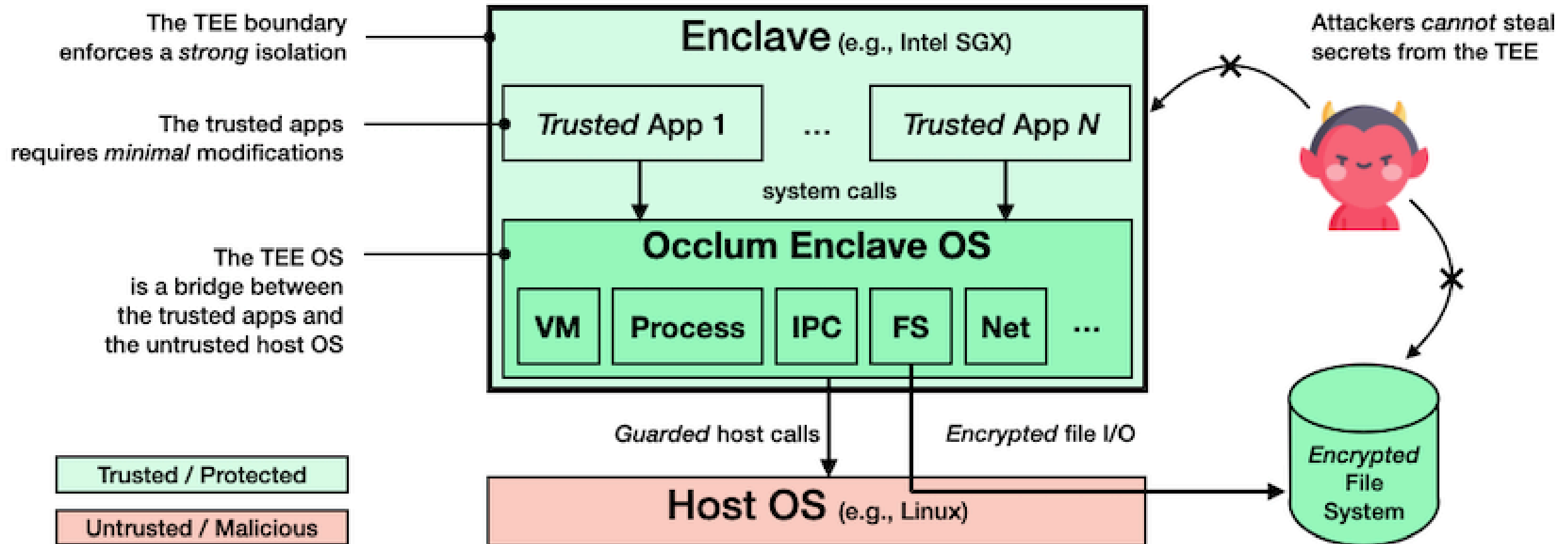
Hardware Selection – Enclave vs CVM



Technology Selection

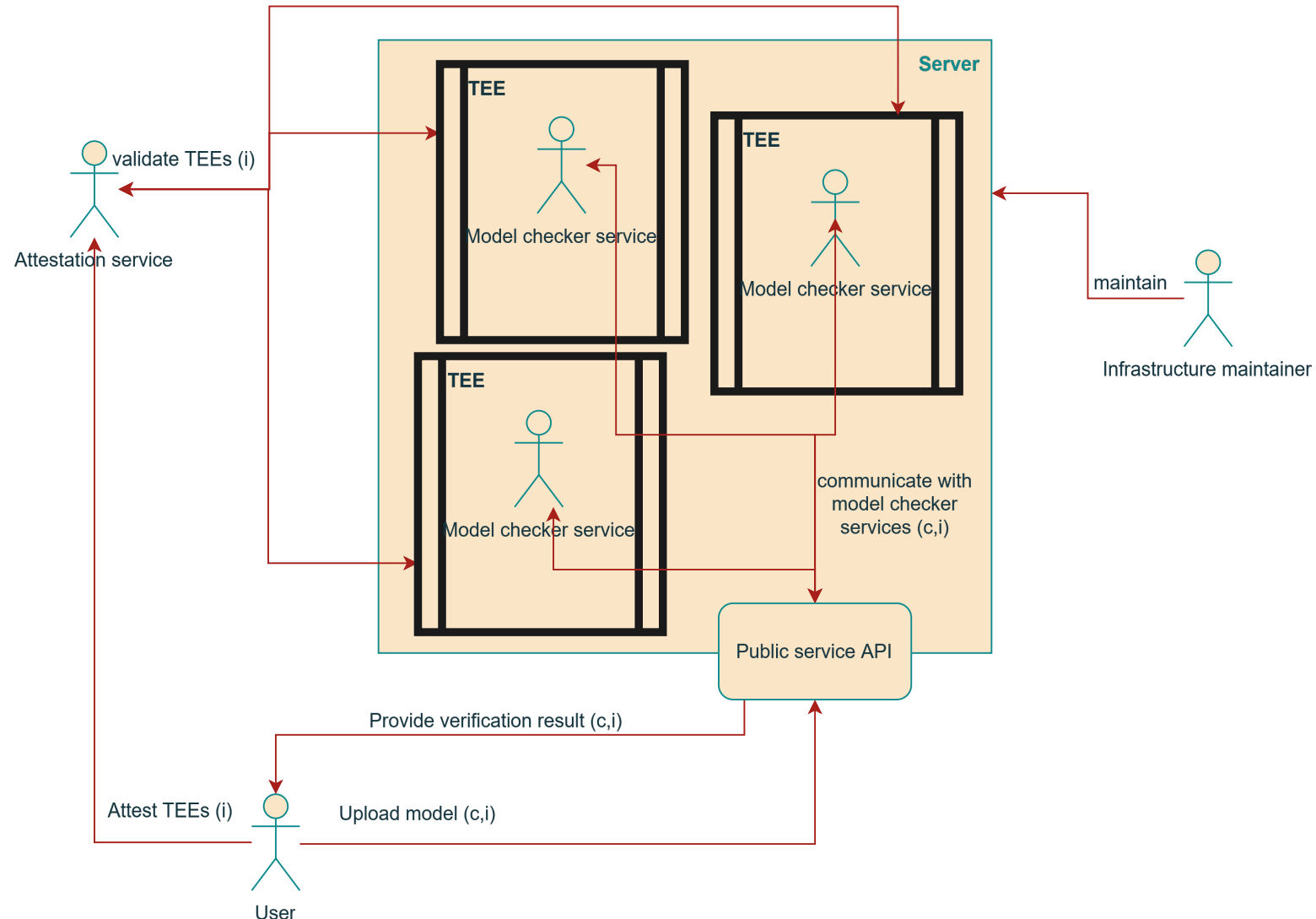


- LibOS

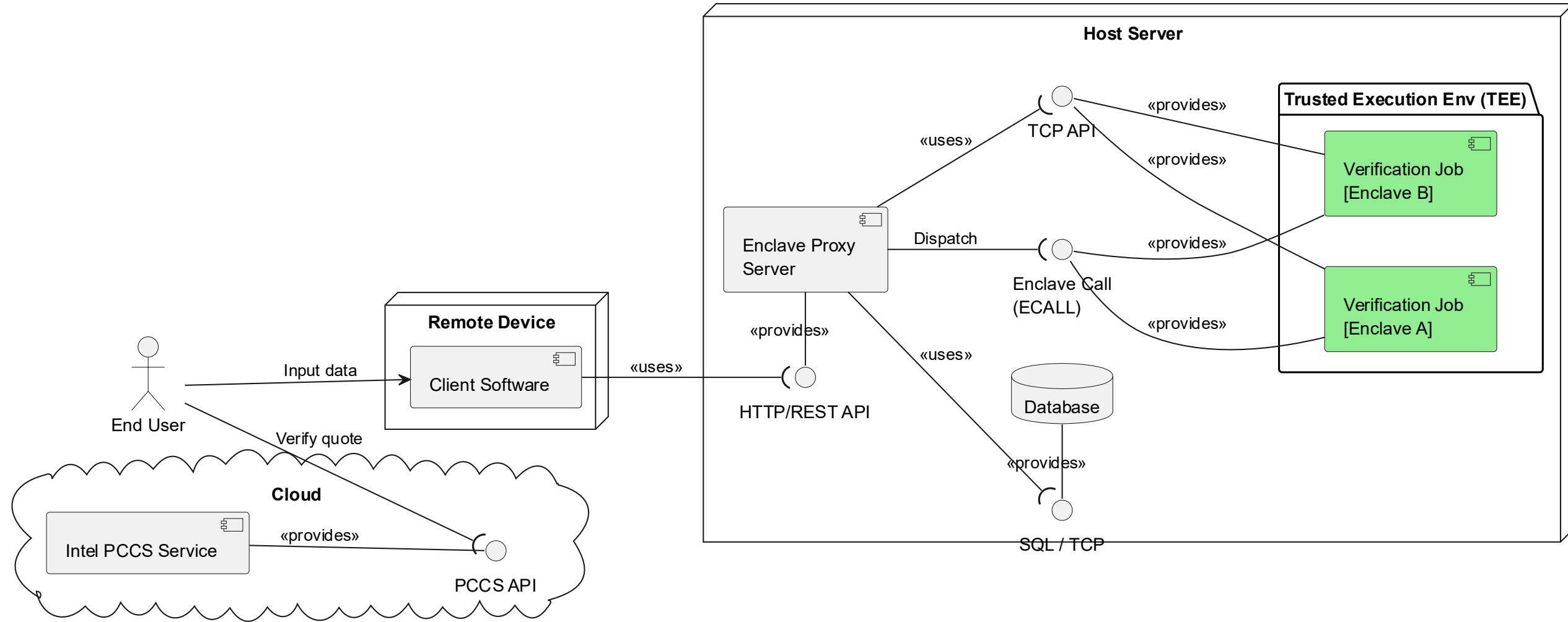


Threat Model & Trust Boundaries

- actors
 - user
 - infrastructure maintainer
 - model checker service
 - attestation service
- assets
 - user's model
 - verification results
 - attestation quote
 - sealing keys
 - code signing keys
 - model checker logic

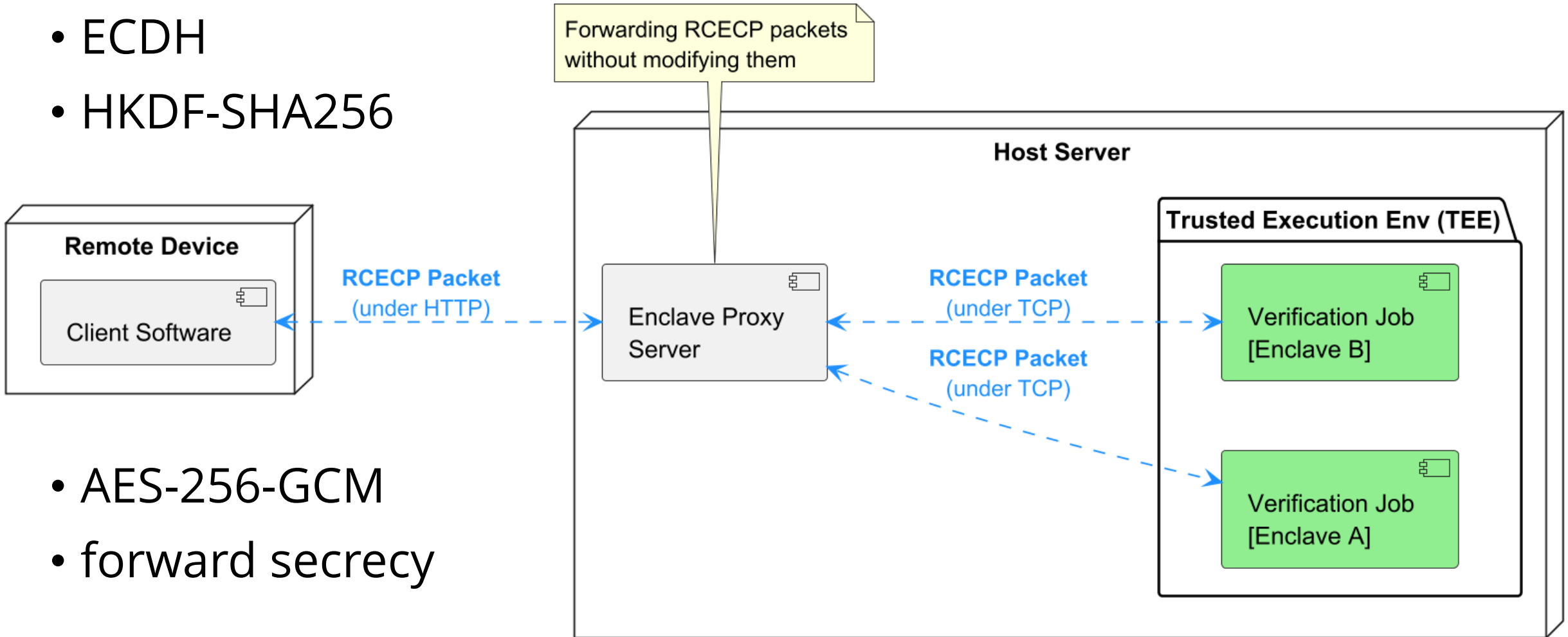


System Architecture Overview



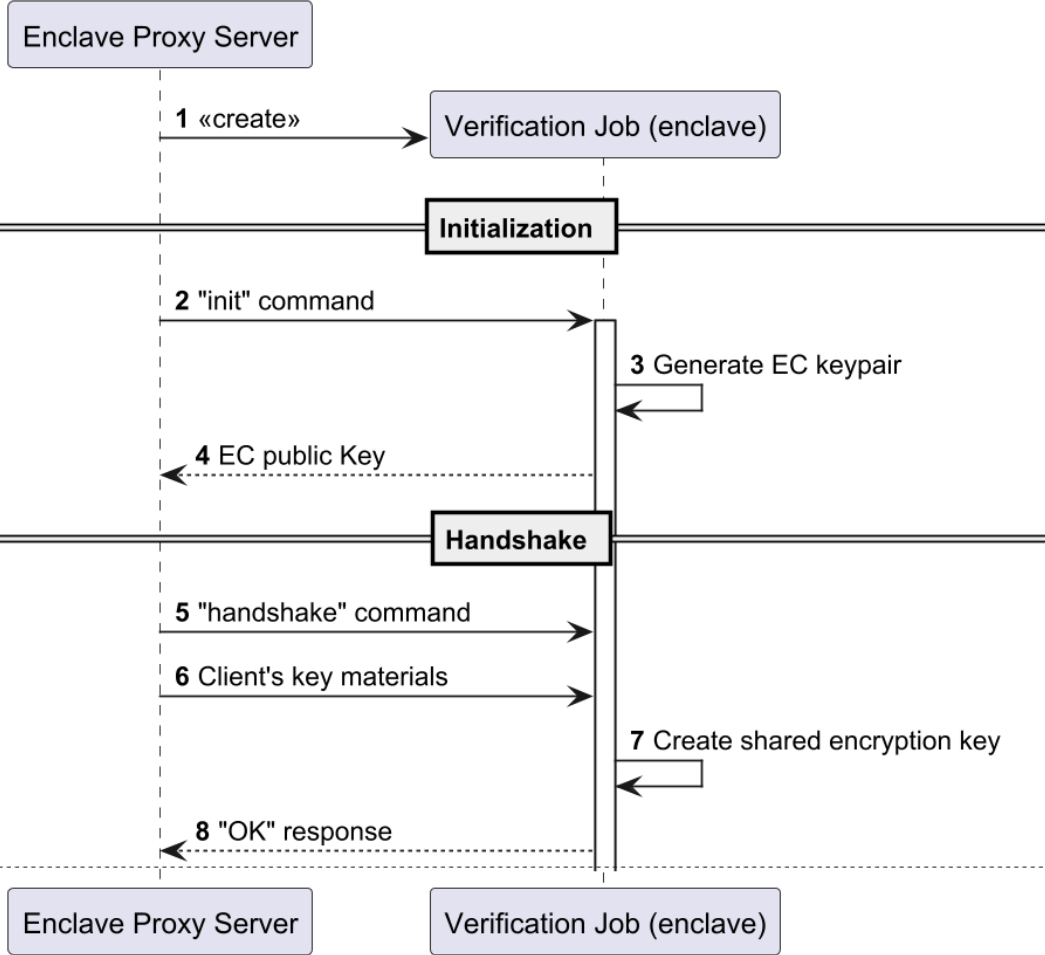
The RCECP Protocol (Secure Communication)

- ECDH
- HKDF-SHA256

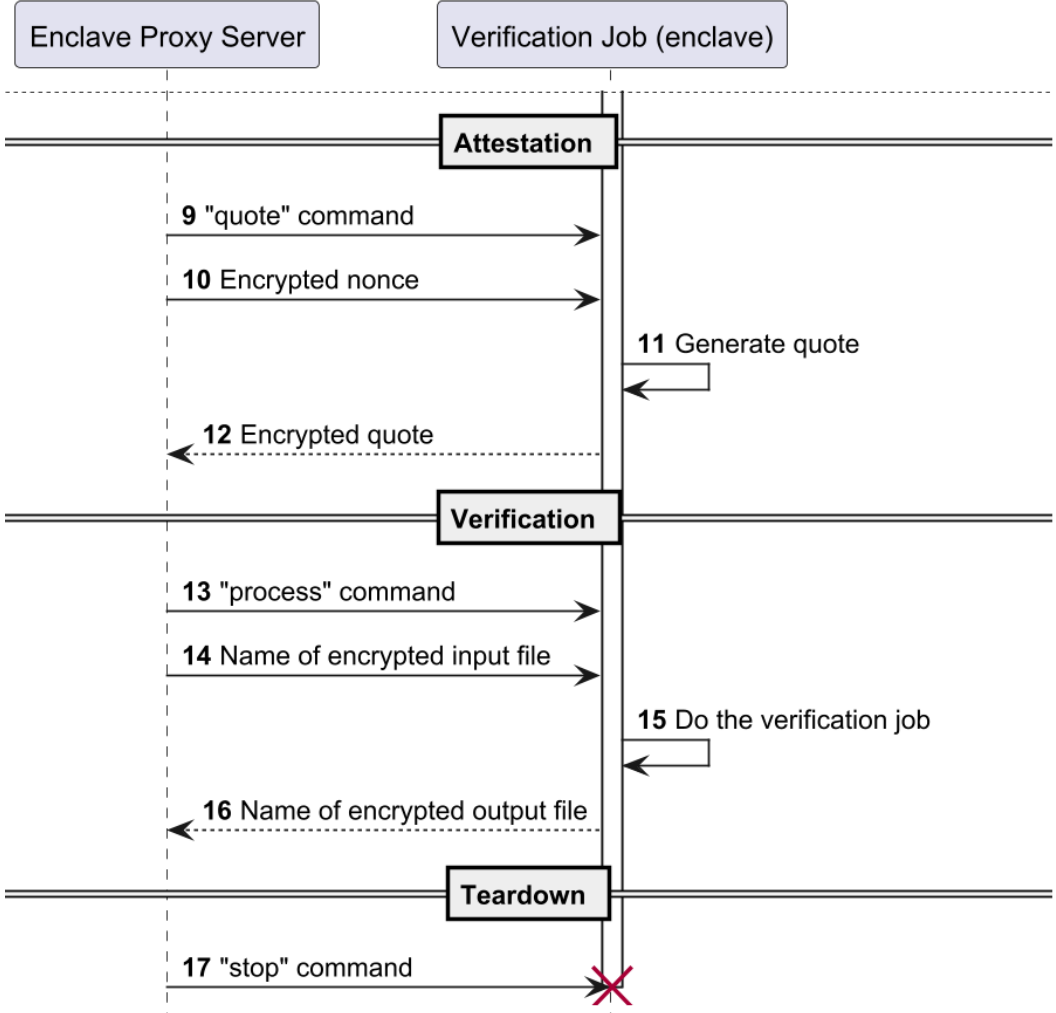


- AES-256-GCM
- forward secrecy

The Verification Lifecycle



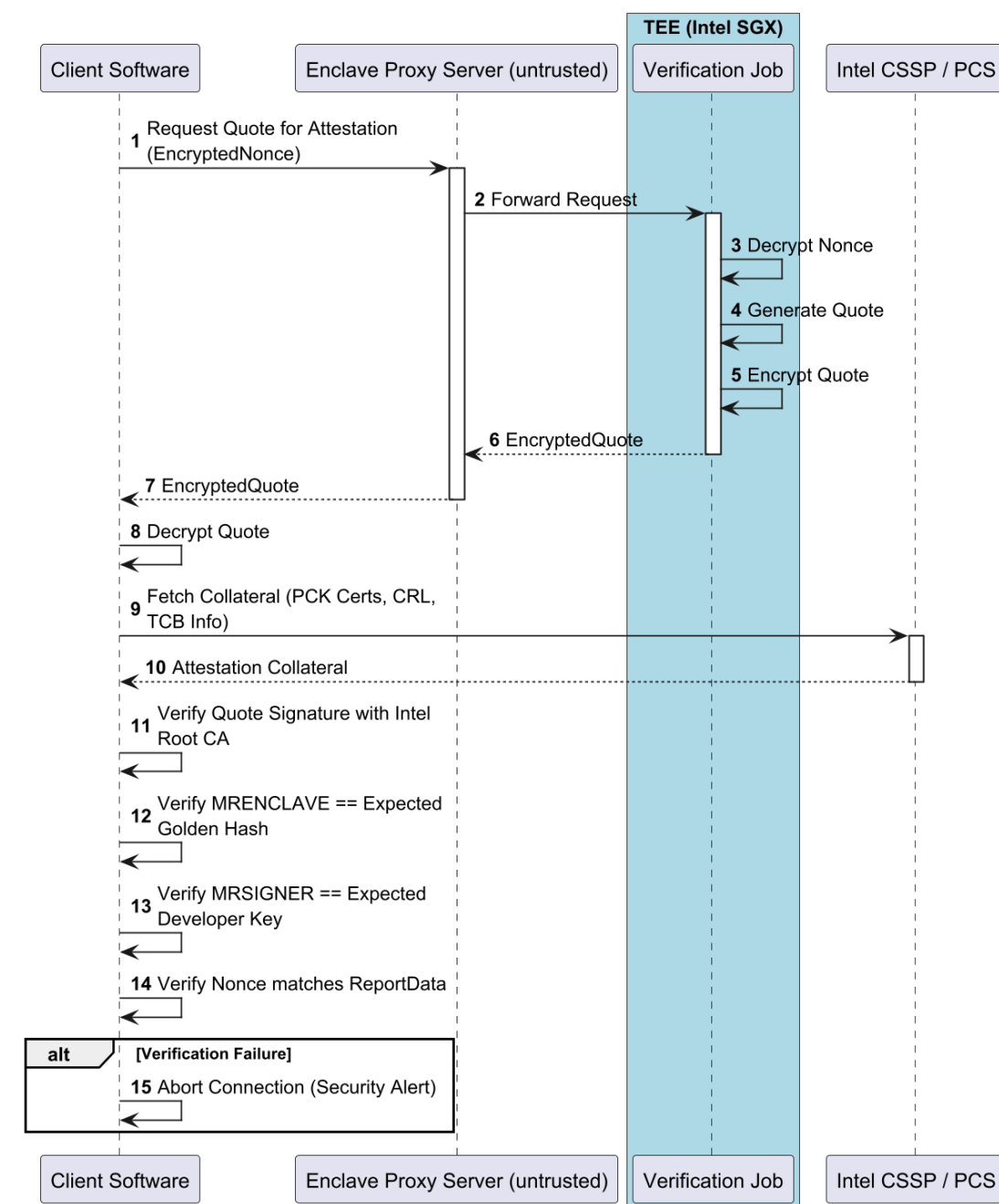
This is 1 of 2



This is 2 of 2

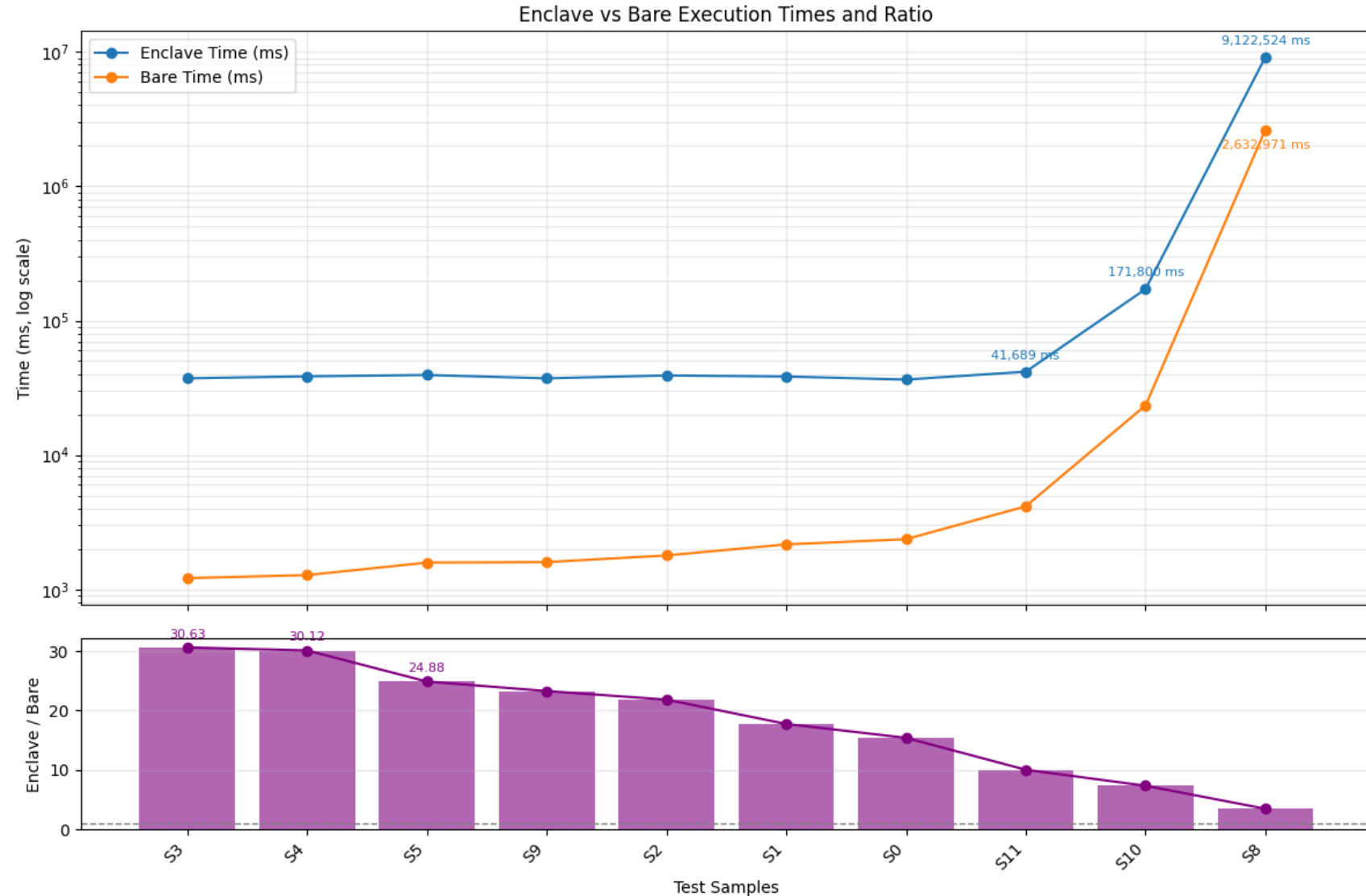
Remote Attestation

- Intel DCAP (Data Center Attestation Primitives)
- What is verified?
 - the enclave
 - the code running inside the enclave
 - the author of the code running inside the enclave



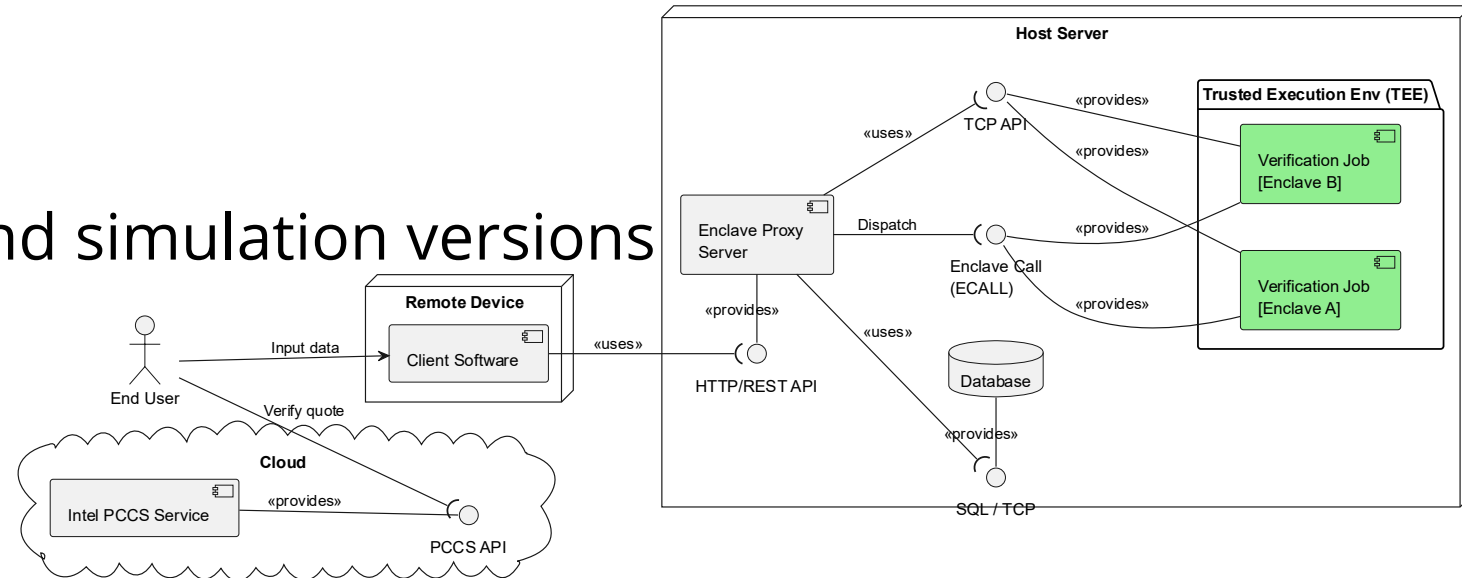
Case Study & Evaluation

- SV-COMP tasks
- 10 samples
- overhead
 - startup
 - encryption
- scalability
 - task duration is important
- success



Conclusion & Future Work

- Confidential Model Checking as a Service using SGX & Occlum
- Deliverables
 - components in Java & C
 - Docker images with SGX and simulation versions
 - GitHub actions for CI/CD
 - thesis
- Future Work
 - optimize resource allocation
 - scale using Kubernetes (Confidential Containers)
 - support additional model checking tools beyond Theta





<https://xkcd.com/1506>

Reviewer questions

Model checking-specific aspects

Q: What properties make model checking different from other applications that could be executed in a TEE-based cloud service?

A:

- model checking
 - computational hardness
 - state-space explosion
 - non-predictable resource usage
- other applications
 - linear run

Protocol contribution

Q: Is RCECP specific to this system / the model checking use case, or could it be reused in other TEE-based scenarios? If it is generic, how does it differ from existing secure communication solutions?

A:

- It isn't specific to model checking, follows an industry standard for secure communications.
- Other implementations:
 - TLS 1.3, Signal protocol, SSH

Result validation, witnesses

Q: "Since model checking results are often cheaper to validate than to compute (verify), could validation be performed locally after confidential verification? How might this influence system design, could this be utilized to further enforce integrity?"

A: It's completely feasible. The client application would need only a little extension which would post-process the results obtained from the verification.